

BkSoD by Ransomware: HDDCryptor Uses Commercial Tools to Encrypt Network Shares and Lock HDDs

- Posted on: [September 14, 2016](#) at 9:02 am
- Posted in: [Ransomware](#)
- Author: [Trend Micro](#)



by Stephen Hilt and William Gamazo Sanchez

While most [ransomware](#) we've seen only target specific file types or folders stored on local drives, removable media and network shares, we were able to uncover a ransomware family that does not discriminate: HDDCryptor. Detected as [Ransom HDDCRYPTOR.A](#), HDDCryptor not only targets resources in network shares such as drives, folders, files, printers, and serial ports via Server Message Block (SMB), but also locks the drive. Such a damaging routine makes this particular ransomware a very serious and credible threat not only to home users but also to enterprises.

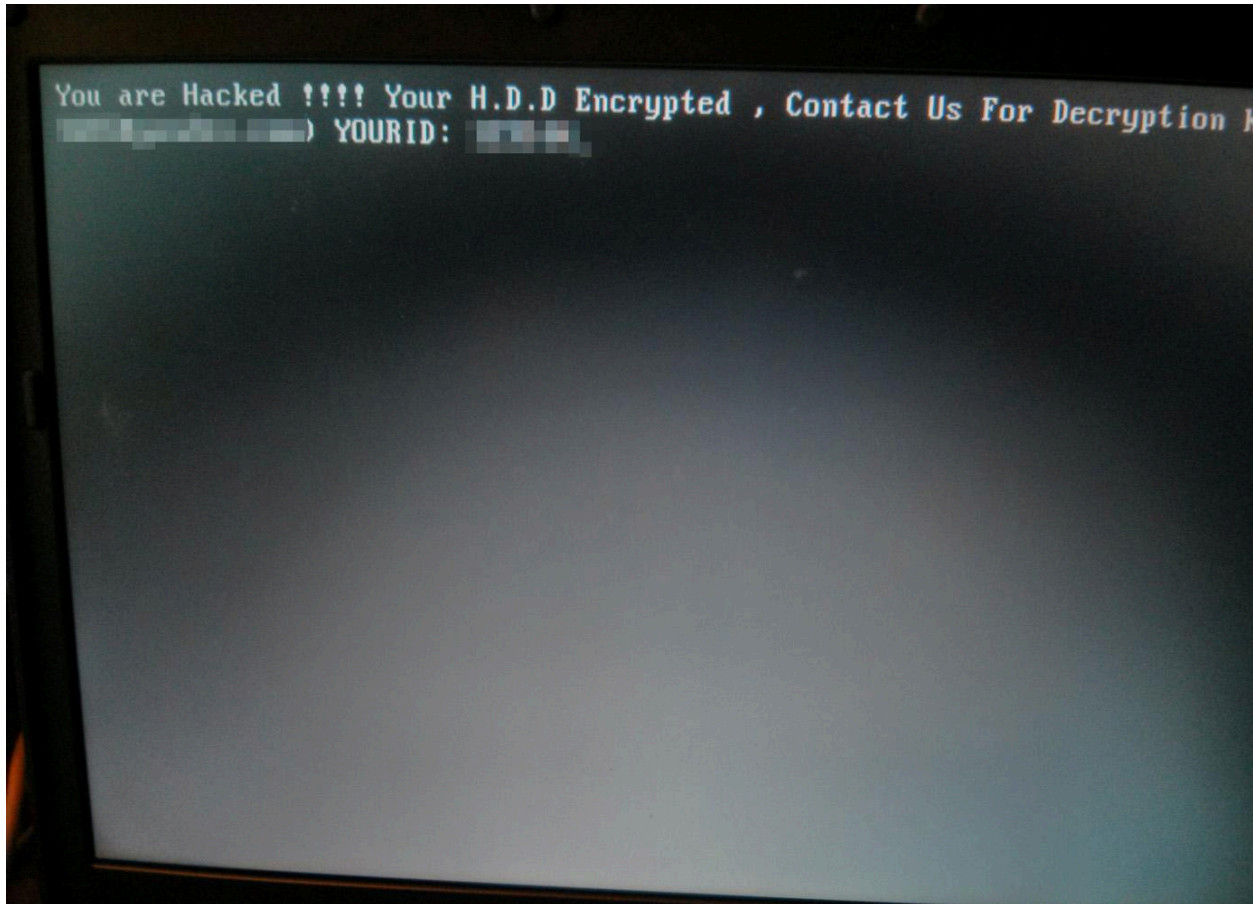


Figure 1. A photo of the ransom note; HDDCryptor uses a hard-coded malware ID (123141), which implies that its operators may only be using a single decryption key.

Infection Vector and Installation

HDDCryptor can infect systems as an executable unsuspectingly downloaded from malicious websites, or as a file dropped by other malware. The ransomware is installed by dropping several components—both legitimate and malicious—to the system's root folder:

- dcapi.dll (detected as Ransom_HDDCRYPTOR.A)
- dccon.exe (used to encrypt the disk drive)
- dencrypt.exe
- dencrypt.sys
- log_file.txt (log of the malware's activities)
- Mount.exe (scans mapped drives and encrypts files stored on them)
- netpass.exe (used to scan for previously accessed network folders)
- netuse.txt (used to store information about mapped network drives)
- netpass.txt (used to store user passwords)

For persistence, it adds a service named *DefragmentService* and executes it via command line.

Network-Mapped Drive Encryption

Digging into HDDCryptor, we found that its network-related behaviors are volatile. There were no observed propagation routines in some samples, while network-encrypting behavior was espied in others. Running one of its components, *mount.exe*, we discover its following functionalities:

- Enumerate all existing mounted drives and encrypt all files
- Find previously connected drives or cached disconnected network paths and connect to them using all credentials captured using the tool *netpass.exe*

Running *mount.exe* with no parameters enumerated all mapped drives via Windows's volume management function *GetLogicalDrives* and encrypted all files stored on them.

```
push    ebp
mov     ebp, esp
sub     esp, 244h
mov     eax, security_cookie
xor     eax, ebp
mov     [ebp+var_4], eax
push    ebx
push    esi
mov     [ebp+pbData], ecx
push    edi
mov     ecx, offset aMountEnumerati ; "mount:Enumerating mount drive to start ..."
call    sub_3627A0
call    ds:GetLogicalDrives
xorps   xmm0, xmm0
mov     esi, eax
mov     [ebp+var_23C], esi
mov     dword ptr [ebp+RootPathName], 5C3A42h
movq    [ebp+var_20], xmm0
movq    [ebp+var_18], xmm0
movq    [ebp+var_10], xmm0
mov     [ebp+var_8], 0
mov     ebx, 2
```

Figure 2. Code showing capability of *mount.exe* to enumerate drives

To reach for previously accessed networked folders (but not mounted drives), HDDCryptor uses a network password recovery freeware (*netpass.exe*). The utility tool extracts credentials of the current session and the result is dumped into a file named *netpass.txt*.

During the same time, the connected drives cache is dumped into a file named *netuse.txt*. The executable then uses the two dump files to access resources in the network cache—even disconnected ones—or whatever network share that was previously accessed. The following image shows *mount.exe* code using the mentioned files:

```

push    ebp
mov     ebp, esp
sub     esp, 0Ch
mov     ecx, offset aMountMountingS ; "mount:mounting share drive..."
push    ebx
push    esi
push    edi
call    sub_3627A0
push    0 ; hTemplateFile
push    0 ; dwFlagsAndAttributes
push    3 ; dwCreationDisposition
push    0 ; lpSecurityAttributes
push    1 ; dwShareMode
push    80000000h ; dwDesiredAccess
push    offset aCDc22Netpass_t ; "C:\\DC22\\netpass.txt"
call    ds:CreateFileA
mov     edi, eax
cmp     edi, 0FFFFFFFFh
jnz     short loc_362DD5
mov     ecx, offset aMountNetpass_t ; "mount:netpass.txt file not accessible.."
call    sub_3627A0

162DCE: ; CODE XREF: sub_362D90+4574j
pop     edi
pop     esi
pop     ebx
mov     esp, ebp
pop     ebp
retn

push    3 ; dwCreationDisposition
push    0 ; lpSecurityAttributes
push    1 ; dwShareMode
push    80000000h ; dwDesiredAccess
push    offset aCDc22Netuse_tx ; "C:\\DC22\\netuse.txt"
mov     duword_3A23D8, edi
call    ds:CreateFileA
mov     edi, eax
cmp     edi, 0FFFFFFFFh
jnz     short loc_363074
mov     ecx, offset aMountNetuse_tx ; "mount:netuse.txt file not accessible.."
call    sub_3627A0
pop     edi
pop     esi
pop     ebx
mov     esp, ebp
pop     ebp
retn

;_363074: ; CODE XREF: sub_362D90+2D11fj
push    0 ; lpFileSizeHigh
push    edi ; hFile
call    ds:GetFileSize
push    eax
mov     [ebp+NumberOfBytesRead], eax
call    sub_3660AD
add     esp, 4
mov     esi, eax
push    [ebp+NumberOfBytesRead]
call    sub_3660AD
add     esp, 4
mov     [ebp+nNumberOfBytesToRead], eax
push    0 ; lpOverlapped
lea     eax, [ebp+NumberOfBytesRead]
push    eax ; lpNumberOfBytesRead
push    [ebp+NumberOfBytesRead] ; nNumberOfBytesToRead
push    esi ; lpBuffer
push    edi ; hFile
call    ebx ; ReadFile
push    offset a0k ; "OK"
push    esi ; char *
xor     ebx, ebx
call    _strchr
add     esp, 8
test    eax, eax
jz      loc_363149

```

Figure 3. Mount.exe code shown using the dump .txt files

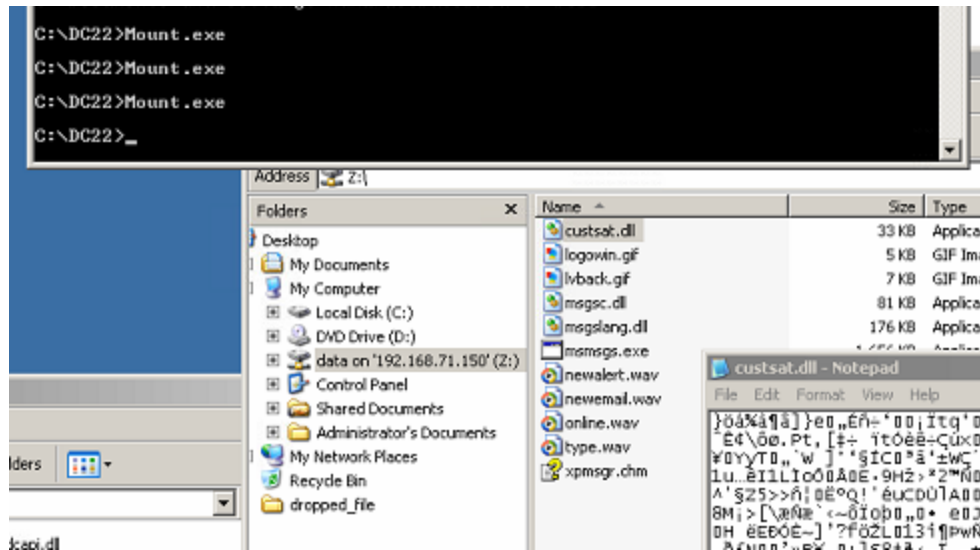


Figure 4. Snapshot of HDDCryptor's encryption routine to mapped drives

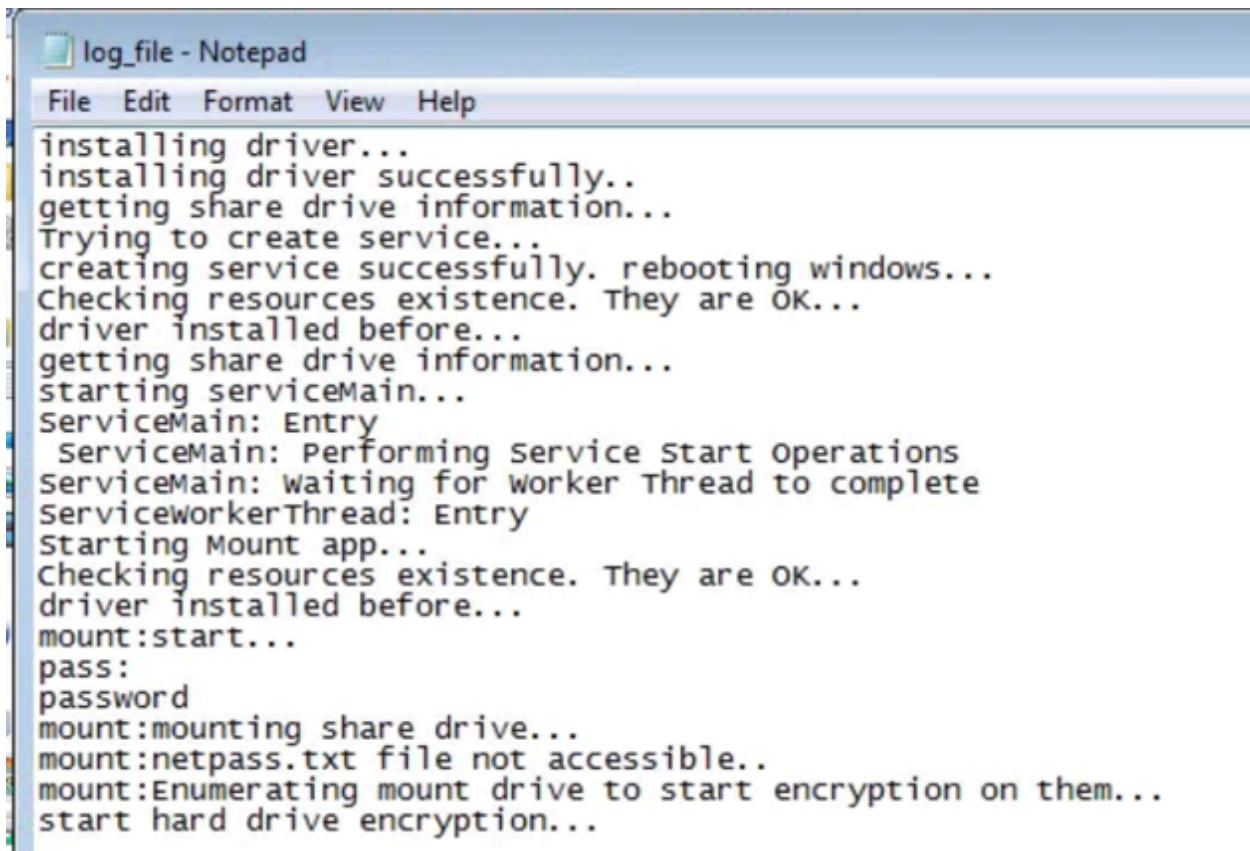


Figure 5. A screenshot of log_file.txt showing HDDCryptor's malicious activities

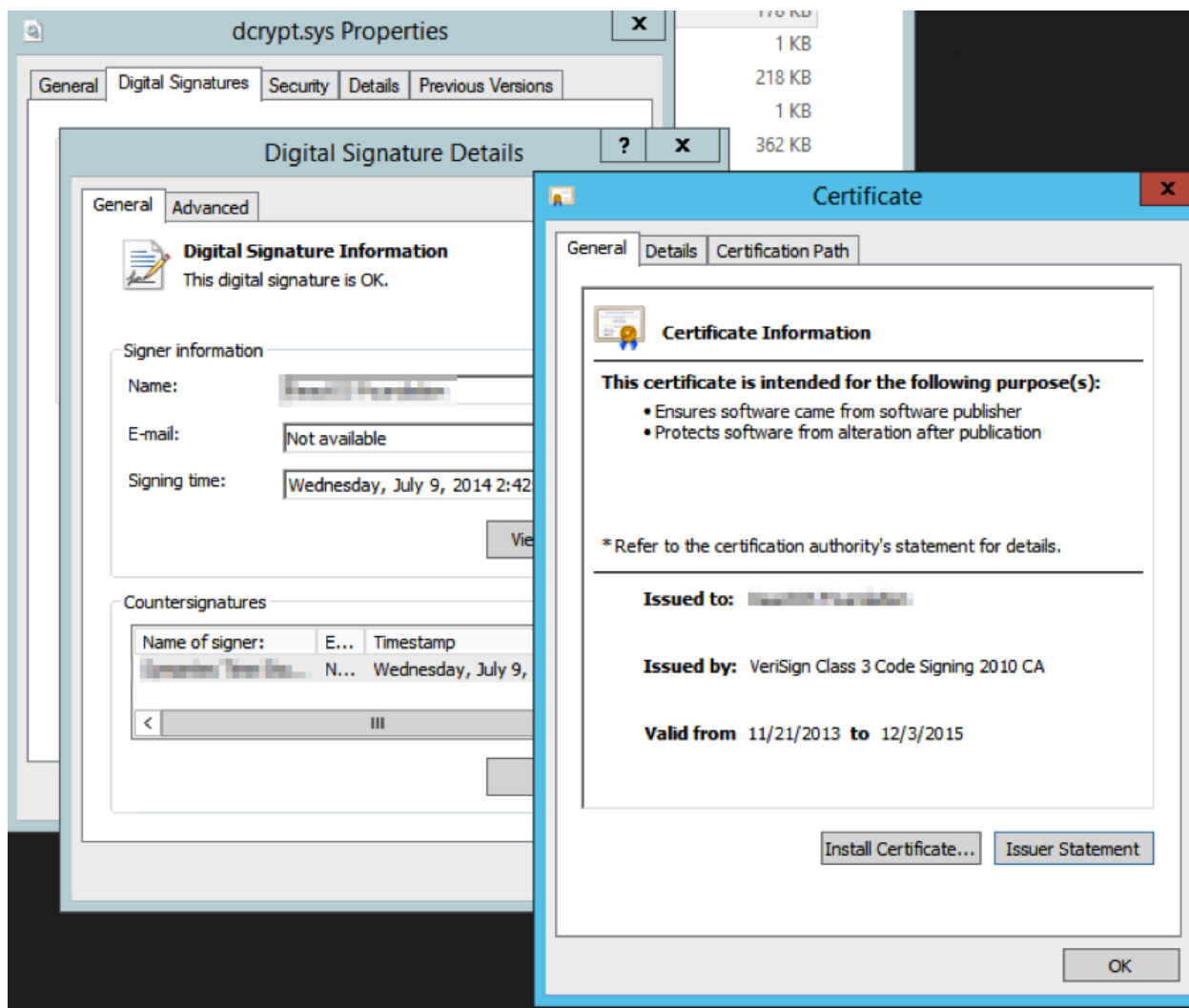


Figure 6. A snapshot of DiskCryptor's properties showing its expired certificates

HDDCryptor uses disk and network file-level encryption via [DiskCryptor](#), an open source disk encryption software that supports AES, Twofish and Serpent encryption algorithms, including their combinations, in XTS mode. It also uses DiskCryptor to overwrite the Master Boot Record (MBR) and adds a modified bootloader to display its ransom note, instead of the machine's normal log-in screen.

In some of the samples we ran, the system was forcefully rebooted (no user interaction needed) after two hours of full disk activity—while the drive is being encrypted—while in others, the affected machine was rebooted twice.

Interestingly, the copy of the DiskCryptor dropped by the samples we analyzed is the same file available in DiskCryptor's download page. Aside from containing expired certificates, the software itself hasn't received an update since September 7, 2014. In contrast, HDDCryptor's

operators seemed to have used a modified version of *netpass.exe*. The version dropped by this ransomware had its properties such as version information stripped out in the binaries. We have reached out and shared our analysis of this ransomware to the developers of these software.

HDDCryptor, like [ransomware as a service](#) (RaaS), embodies how little effort can go a long way. At the crux of it is how HDDCryptor utilizes commercially available software to do its nefarious bidding, and ultimately how affected end users and businesses foot the bill for these cybercriminals.

Trend Micro Ransomware Solutions

As ransomware continues to wreak havoc on users, it looks as though it can only up the ante. Considering the severe damage HDDCryptor poses to end users and especially businesses, it is crucial to have preventive measures in place, such as a [strengthened backup policy](#), as well as a proactive, multilayered approach to security: from the [gateway](#), [endpoints](#), [networks](#), and [servers](#).

PROTECTION FOR ENTERPRISES

- **Email and Gateway Protection**

[Trend Micro Cloud App Security](#), [Trend Micro™ Deep Discovery™ Email Inspector](#) and [InterScan™ Web Security](#) address ransomware in common delivery methods such as email and web.

Spear phishing protection

Malware Sandbox

IP/Web Reputation

Document exploit detection

- **Endpoint Protection**

[Trend Micro Smart Protection Suites](#) detects and stops suspicious behavior and exploits associated with ransomware at the endpoint level.

Ransomware Behavior Monitoring

Application Control

Vulnerability Shielding

Web Security

- **Network Protection**

[Trend Micro Deep Discovery Inspector](#) detects malicious traffic, communications, and other activities associated with attempts to inject ransomware into the network.

Network Traffic Scanning

Malware Sandbox

Lateral Movement Prevention

- **Server Protection**

[Trend Micro Deep Security™](#) detects and stops suspicious network activity and shields servers and applications from exploits.

Webserver Protection

Vulnerability Shielding

Lateral Movement Prevention

PROTECTION FOR [SMALL-MEDIUM BUSINESSES](#) AND [HOME USERS](#)

- **Protection for Small-Medium Businesses**

[Trend Micro Worry-Free™ Business Security Advanced](#) offers cloud-based email gateway security through Hosted Email Security that can detect and block ransomware.

Ransomware behavior monitoring

IP/Web Reputation

- **Protection for Home Users**

[Trend Micro Security 10](#) provides robust protection against ransomware by blocking malicious websites, emails, and files associated with this threat.

IP/Web Reputation

Ransomware Protection

Related Hashes detected as Ransom_HDDCRYPTOR.A:

SHA-1:

177843629CD1DC4345B03E48574EED12D0551CE6
263D14F535C264AA254FBEE0B66E94A32C156A4C
4080BB3A28C2946FD9B72F6B51FE15DE74CBB1E1
719C3B897826169190FFCAF8EC111E78ACD1613E
C63AFCE8C54362A6D626F660C3A15CEC3E723C1C
6A5250A24439CB760E91C228B56D991A717E556A

SHA-256:

e141f564003773d4fe3ef462458a041a871699fb7dc646632cf00afac4870779
1b44a3b1dec865a96e44f2b556f19682fd844ebe3e7b0577bd7e58d307fcb4f
2ecc525177ed52c74ddaaacd47ad513450e85c01f2616bf179be5b576164bf63